YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

PHP2Shell
Eray Atalay



1. Yönetici Özeti **2**
2. Zafiyet Karşılaştırma Tablosu **2**
3. Teknik Analiz ve İstismar Mekanizması **3**
3.1. CVE-2026-109618: session.upload_progress İşleyicisinde Use-After-Free (UAF) 3
3.2. CVE-2026-109619: multipart/form-data (RFC 1867) İstek Ayrıştırıcısında Bellek ve Durum Kusuru 4
3.3. İki Zafiyetin Teknik Karşılaştırma Özeti 4
4. Kronoloji ve Sızıntı Süreci **5**
4.1 İlk Sızıntı (Hacker News & Sosyal Medya) 5
4.2 Doğrulama ve PHP Acil Durum Duyurusu 5
4.3 İlk Saldırı Denemeleri ve Önleyici Kapatmalar 5
4.4 Yama Yayını ve Geniş Çaplı Tarama 5
5. Tehdit Avcılığı ve Tespit Yöntemleri **6**
5.1 Process Tree Anomalileri 6
5.2 Dosya Sistemi ve Kalıcılık Tespiti 6
5.3 Envanter Tespiti (KQL / Defender Örneği) 6
5.4 Sigma Tespit Kuralı (Process Creation / Host-Based) 7
6. Azaltma ve Çözüm Önerileri (Mitigation & Remediation) **8**
6.1 Acil Yama Geçişi (Birincil Çözüm): 8
6.2 EOL Sürümlerin İzolasyonu (PHP 5.x, 7.x, 8.0, 8.1): 8
6.3 Web Sunucusu Seviyesinde multipart/form-data Engellemesi: 8
7. Kaynakça **9**

1. Yönetici Özeti

20 Ekim 2026 tarihinde, PHP çekirdeğinde (PHP Core) yer alan ve koordineli açıklama (embargo) sürecinde olan iki kritik güvenlik açığına dair bilgiler sızdırılmıştır. Siber güvenlik topluluğunda PHP2Shell olarak adlandırılan CVE-2026-109618 ve CVE-2026-109619 zafiyetleri, birbirleriyle zincirlenerek (exploit chain) kimlik doğrulaması gerektirmeksizin uzaktan kod çalıştırılmasına (RCE) olanak tanımaktadır. Zafiyetlerin ciddiyeti ve sızıntı sonrası oluşan sıfırıncı gün (0-day) riski nedeniyle PHP Güvenlik Ekibi acil durum yama takvimini öne çekmiş, Hollanda Ulusal Siber Güvenlik Merkezi (NCSC), Hollanda Temsilciler Meclisi ve Wikimedia Phabricator gibi kritik kurumlar yama yayınlanana kadar sistemlerini tedbiren çevrimdışı (offline) duruma getirmiştir.

2. Zafiyet Karşılaştırma Tablosu

Özellik	CVE-2026-109618	CVE-2026-109619
Kod Adı / Kampanya	PHP2Shell (Aşama 1 / İstek İşleme)	PHP2Shell (Aşama 2 / RCE Zinciri)
Etkilenen Bileşen	PHP Core (multipart/form-data & Session)	PHP Core (Bellek ve Ayrıştırma Motoru)
CVSS v4.0 Skoru	9.2 (Kritik)	9.2 (Kritik)
Saldırı Vektörü	Ağ Üzerinden (HTTP/HTTPS POST)	Ağ Üzerinden (HTTP/HTTPS POST)
Etkilenen Sürümler	PHP 5.4 – PHP 8.x (Tüm Dallar)	PHP 5.4 – PHP 8.x (Tüm Dallar)

Tablo 1: Zafiyet Karşılaştırma Tablosu

3. Teknik Analiz ve İstismar Mekanizması

PHP2Shell zafiyetlerinin en kritik ortak özelliği, saldırının uygulama katmanı (script) çalışmaya başlamadan önce, doğrudan PHP yorumlayıcısının (PHP Core / Zend Engine) gelen HTTP isteğini ayrıştırma aşamasında (RINIT / Request Initialization) tetiklenmesidir. Bu nedenle hedef sistemdeki web uygulamasının (WordPress, Magento, Laravel vb.) kimlik doğrulama istemesi, session_start() fonksiyonunu hiç çağırmaması veya bakım modunda (maintenance mode) olması istismarı engellemez.

Sızdırılan teknik analizler ve kaynak kod incelemeleri doğrultusunda iki CVE kaydının ayrıştığı noktalar şunlardır:

3.1. CVE-2026-109618: session.upload_progress İşleyicisinde Use-After-Free (UAF)

- **Etkilenen Alt Sistem**: ext/session (php_session_rfc1867_callback fonksiyonu)
- **Zafiyet Sınıfı:** CWE-416 (Use-After-Free / Bellek Bozulması)
- **CVSS v4.0 Skoru:** 9.2 (Kritik)

Teknik Kök Neden: PHP 5.4'ten itibaren varsayılan olarak açık gelen **session.upload_progress.enabled = 1** ayarı, multipart/form-data tipinde bir POST isteği içinde **PHP_SESSION_UPLOAD_PROGRESS** parametresi ve saldırganın belirlediği bir oturum çerezi (PHPSESSID) gönderildiğinde otomatik olarak devreye girer. Uygulama kodu içinde oturum başlatılmasa bile PHP motoru arka planda oturum verisini başlatır ve dosya yükleme ilerlemesini takip etmek için **php_session_rfc1867_callback** işleyicisini çağırır.

PHP kaynak kodunda (ext/session/session.c, satır 3316 ve 3342 civarı), bu callback fonksiyonu yükleme ilerlemesi dizisi (array) içerisindeki elemanlara işaret eden iki adet ham bellek işaretçisi (raw pointer) tutmaktadır. Özel olarak kurgulanmış çok parçalı (multipart) yükleme parçaları ve oturum yeniden yükleme/serileştirme (BG(serialize)) durumları tetiklendiğinde:

1. PHP, alttaki oturum dizisini (array) bellekten serbest bırakır (free).
2. Ancak **php_session_rfc1867_callback** içerisindeki ham işaretçiler (dangling pointers) güncellenmez ve serbest bırakılmış bellek alanını göstermeye devam eder.
3. Saldırgan aynı istek akışı içerisinde belleği kontrollü verilerle yeniden doldurarak (heap grooming / spraying), serbest bırakılan bellek bloğunun üzerine sahte zval yapıları veya fonksiyon işaretçileri yazar ve PHP worker süreci (php-fpm, apache2) üzerinde doğrudan rastgele kod çalıştırma (RCE) elde eder.

3.2. CVE-2026-109619: multipart/form-data (RFC 1867) İstek Ayrıştırıcısında Bellek ve Durum Kusuru

- **Etkilenen Alt Sistem:** PHP Core (main/rfc1867.c — Multipart Request Parser & SAPI Post Handler)
- **Zafiyet Sınıfı:** Bellek Bozulması / İstek Ayrıştırma Hatası (Adjacent Parsing Flaw)
- **CVSS v4.0 Skoru:** 9.2 (Kritik)

Teknik Kök Neden: CVE-2026-109619, doğrudan PHP çekirdeğinin HTTP POST gövdelerindeki multipart/form-data sınırlarını (boundary), başlıklarını ve değişkenlerini ayrıştıran RFC 1867 motorundaki ikinci bir kusuru temsil etmektedir.

1. **Yapılandırma Kısıtlamalarını Aşma (Bypass):** CVE-2026-109618 yalnızca oturum yükleme ilerlemesi (session.upload_progress) üzerinden tetiklenirken, CVE-2026-109619 doğrudan multipart ayrıştırma motorunda yer alır. Bu durum, sistem yöneticileri php.ini üzerinden **session.upload_progress.enabled = Off** ayarını yapsa dahi, PHP'nin multipart gövdesini okurken zafiyetli kod yoluna girmeye devam etmesine neden olur. (PHP çekirdek geliştiricisi Gina Peter Banyard'ın "ini ayarları yeterli değil, tek çözüm yamalamak veya sunucuyu kapatmak" uyarısının temel nedeni bu ikinci vektördür.)
2. **İstismar Zinciri ve Bağımsız Tetiklenme:** Sınır (boundary) ayrıştırma ve tampon (buffer) yönetimi sırasında oluşan bu kusur, hem tek başına bellek bozulması yaratarak RCE tetiklemek hem de CVE-2026-109618'deki Use-After-Free zafiyeti için gereken bellek düzenini (heap layout) hazırlamak ve istismarı kararlı (reliable) hale getirmek için kullanılmaktadır.

3.3. İki Zafiyetin Teknik Karşılaştırma Özeti

Kriter	CVE-2026-109618	CVE-2026-109619
Hedef Fonksiyon / Modül	ext/session (php_session_rfc1867_callback)	main/rfc1867.c (Core Multipart Parser)
Kök Neden (Root Cause)	Serbest bırakılan diziye ait iki ham işaretçinin (raw pointer) kullanılmaya devam edilmesi (Use-After-Free)	Multipart gövde/boundary ayrıştırma sırasında bellek ve durum yönetimi kusuru
Tetikleme Koşulu	PHP_SESSION_UPLOAD_PROGRESS içeren multipart POST isteği	Özel kurgulanmış multipart/form-data HTTP POST isteği
upload_progress = Off Etkisi	Bu vektörü büyük ölçüde devre dışı bırakır	Engellemez (Ayrıştırıcı yine de çalışır)
Nginx/Apache Multipart Engeli	İstek PHP'ye ulaşmadığı için engeller	İstek PHP'ye ulaşmadığı için engeller

Tablo 2: İki Zafiyetin Teknik Karşılaştırılması

4. Kronoloji ve Sızıntı Süreci

4.1 İlk Sızıntı (Hacker News & Sosyal Medya)

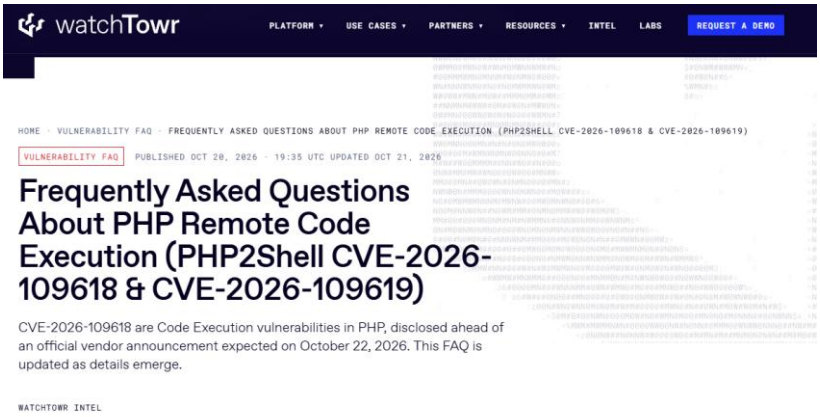
20 Ekim 2026 - 15:20 UTC

Normalde 22 Ekim'de açıklanması planlanan iki kritik PHP RCE zafiyetine dair bilgiler "Tell HN" başlığıyla sızdırıldı ve hızla X/Mastodon üzerinde yayıldı.

4.2 Doğrulama ve PHP Acil Durum Duyurusu

20 Ekim 2026 - Akşam

Siber güvenlik firması watchTowr zafiyetlerin gerçek olduğunu doğruladı. PHP Güvenlik Ekibi ve CERT-EU (Advisory 2026-018), CVSS 9.2 skorlu iki açık için yama tarihini 21 Ekim 14:00 UTC olarak öne çekti.



Görsel 1: Zafiyetlerin watchTowr Tarafından Doğrulanması

4.3 İlk Saldırı Denemeleri ve Önleyici Kapatmalar

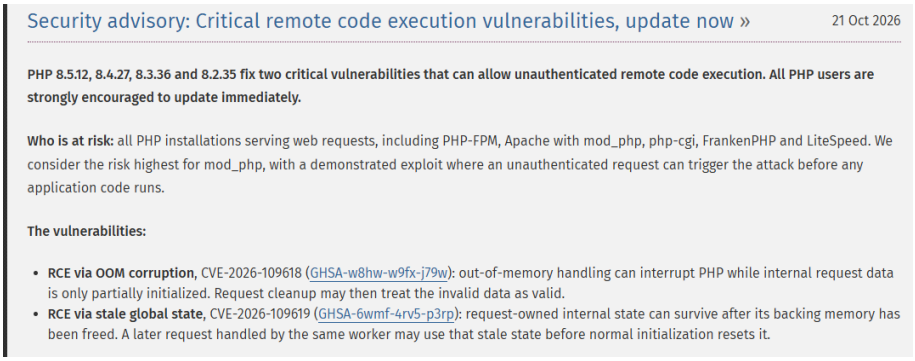
21 Ekim 2026 - 07:43 UTC

Cloudflare, PHP sunucularını hedef alan erken aşama istismar denemeleri tespit ettiğini duyurdu ve acil WAF kurallarını devreye aldı. Pek çok kamu ve teknoloji kuruluşu PHP servislerini geçici olarak durdurdu.

4.4 Yama Yayını ve Geniş Çaplı Tarama

21 Ekim 2026 - 14:00 UTC

PHP desteklenen sürümler için resmi yamaları yayınladı. Yama analizleriyle (patch diffing) birlikte dakikalar içinde kitlesel istismar taramalarının başlaması beklendiğinden kritik alarm seviyesi korundu.



Görsel 2: PHP Resmi Yama Yayını

5. Tehdit Avcılığı ve Tespit Yöntemleri

Sistemlerde PHP2Shell istismarını veya istismar sonrası aktiviteleri (post-exploitation) tespit etmek için aşağıdaki kontroller uygulanmalıdır:

5.1 Process Tree Anomalileri

Bir web sunucusu veya PHP worker sürecinin child process olarak shell veya ağ aracı çalıştırması en net istismar göstergesidir:

Parent Process: php-fpm, php-cgi, httpd, apache2, nginx

Şüpheli Alt Süreçler: sh, bash, dash, curl, wget, python, perl, nc, busybox, whoami, id

5.2 Dosya Sistemi ve Kalıcılık Tespiti

- Web dizinlerinde (/var/www/html, public_html vb.) yakın zamanda oluşturulmuş veya değiştirilmiş .php, .phtml, .phar uzantılı dosyaların (Web Shell) taranması.
- Güvenlik araştırmacıları, zafiyetin sıfırıncı gün olarak daha önceden kullanılmış olma ihtimaline karşı Haziran 2026'ya kadar geriye dönük log ve dosya bütünlüğü (FIM) kontrolü yapılmasını önermektedir.

5.3 Envanter Tespiti (KQL / Defender Örneği)

Ağdaki EOL (End-of-Life) PHP sürümlerini tespit etmek için kullanılabilecek sorgu mantığı:

```
DeviceTvmSoftwareInventory
| where SoftwareName matches regex @"(?i)^php([0-9]+(\.[0-9]+)?)?-(cli|fpm|cgi|common)$"
| summarize Devices = dcount(DeviceId) by SoftwareName, SoftwareVersion
```

5.4 Sigma Tespit Kuralı (Process Creation / Host-Based)

```
title: PHP Worker Spawning Interactive Shell or Recon Tool (php2shell)
id: 8c3f7b2a-1e4a-4a8b-9d21-f19e20261096
status: experimental
description: Detects suspicious child processes spawned by PHP-FPM, Apache, or web server daemons (CVE-2026-109618 / CVE-2026-109619).
references:
    - https://www.huntress.com/blog/php2shell-leaked-critical-php-vulnerabilities
author: Threat Intel Team
date: 2026-10-21
tags:
    - attack.execution
    - attack.t1059.004
    - cve.2026-109618
    - cve.2026-109619
logsource:
    category: process_creation
    product: linux
detection:
    parent_process:
    ParentImage|endswith:
    - '/php-fpm'
    - '/php-fpm8.2'
    - '/php-fpm8.3'
    - '/php-fpm8.4'
    - '/php-cgi'
    - '/apache2'
    - '/httpd'
    - '/nginx'
    suspicious_children:
    Image|endswith:
    - '/sh'
    - '/bash'
    - '/dash'
    - '/zsh'
    - '/python3'
    - '/perl'
    - '/curl'
    - '/wget'
    - '/nc'
    - '/busybox'
    condition: parent_process and suspicious_children
level: critical
```

6. Azaltma ve Çözüm Önerileri (Mitigation & Remediation)

KRİTİK UYARI: Yapılandırma Ayarlarının Sınırlılığı

GMO Flatt Security ve PHP Güvenlik Ekibi değerlendirmelerine göre, yalnızca php.ini üzerinden 'session.upload_progress.enabled = Off' yapmak veya 'memory_limit' değiştirmek tüm istismar vektörlerini tam olarak kapatmamaktadır. Bu ayarlar yalnızca risk azaltıcı geçici katman olarak uygulanmalı, asıl çözüm olarak mutlaka resmi PHP güvenlik yamaları geçilmelidir.

6.1 Acil Yama Geçişi (Birincil Çözüm):

Desteklenen PHP 8.2, 8.3, 8.4 ve 8.5 sürümleri için yayınlanan resmi güvenlik güncellemeleri paket yöneticileri veya konteyner imajları üzerinden derhal uygulanmalı ve ardından PHP-FPM / Apache servisleri yeniden başlatılmalıdır.

6.2 EOL Sürümlerin İzolasyonu (PHP 5.x, 7.x, 8.0, 8.1):

PHP 8.1 ve öncesi sürümler resmi PHP yaması almayacaktır. Ubuntu/Debian, RHEL veya CloudLinux backport yamaları kontrol edilmeli, yama sağlanamıyorsa bu sistemler derhal izole edilmeli veya üst sürüme yükseltilmelidir.

6.3 Web Sunucusu Seviyesinde multipart/form-data Engellemesi:

Yama uygulanana kadar dosya yükleme özelliğinin kritik olmadığı sistemlerde istekler PHP'ye ulaşmadan önce Nginx veya Apache katmanında reddedilmelidir.

```
# Nginx Geçici Engelleme:
 if ($http_content_type ~* "multipart/form-data") {
            return 403;
 }

 # Apache (.htaccess / vhost) Geçici Engelleme:
 RewriteEngine On
 RewriteCond %{HTTP:Content-Type} multipart/form-data [NC]
 RewriteRule ^ - [F]
```

7. Kaynakça

[1] CERT-EU (2026). Security Advisory 2026-018: Two Critical Vulnerabilities in PHP (CVE-2026-109618, CVE-2026-109619), CVSS v4.0 Score 9.2. Yayın Tarihi: 20 Ekim 2026.

[2] PHP Security Team (2026). Upcoming Critical PHP Security Release & Official Patch Notes (21 October 2026, 14:00 UTC). https://www.php.net/

[3] Huntress Rapid Response (2026). Hammond, J. 'Rapid Response: php2shell, Leaked Critical PHP Vulnerabilities (CVE-2026-109618 & CVE-2026-109619)'. Yayın Tarihi: 21 Ekim 2026. https://www.huntress.com/blog/php2shell-leaked-critical-php-vulnerabilities

[4] Sansec Threat Research (2026). 'Critical PHP RCE: CVE-2026-109618 and CVE-2026-109619 (PHP2Shell)'. Yayın Tarihi: 21 Ekim 2026. https://sansec.io/research/php2shell

[5] watchTowr Labs (2026). 'PHP Remote Code Execution FAQ: CVE-2026-109618 & CVE-2026-109619'. Yayın Tarihi: 20 Ekim 2026. https://watchtowr.com/intelligence/php-cve-2026-109618-faq/

[6] Sophos Counter Threat Unit (2026). 'Proof-of-concept exploit released for PHP vulnerabilities (CVE-2026-109618, CVE-2026-109619)'. Yayın Tarihi: 21 Ekim 2026. https://www.sophos.com/blog/proof-of-concept-exploit-released-for-php-vulnerabilities-109618-109619

[7] Brandefense Research Team (2026). 'PHP2Shell: Two Critical PHP Flaws Reported as RCE, CVE-2026-109618 and CVE-2026-109619'. Yayın Tarihi: 21 Ekim 2026. https://brandefense.io/blog/php2shell-php-rce-cve-2026-109618-109619/

[8] Veridyen Güvenlik Araştırmaları & GMO Flatt Security (2026). 'PHP2Shell: İki Kritik PHP Güvenlik Açığı ve session.upload_progress Değerlendirmesi'. Yayın Tarihi: 21 Ekim 2026. https://www.veridyen.com/blog/php2shell-kritik-acik

[9] Wikipedia Contributors (2026). 'PHP2Shell (CVE-2026-109618 and CVE-2026-109619)'. Wikipedia, The Free Encyclopedia. https://en.wikipedia.org/wiki/PHP2Shell

YILDIZ

SİBER TEHDİT İSTİHBARATI TAKIMI

